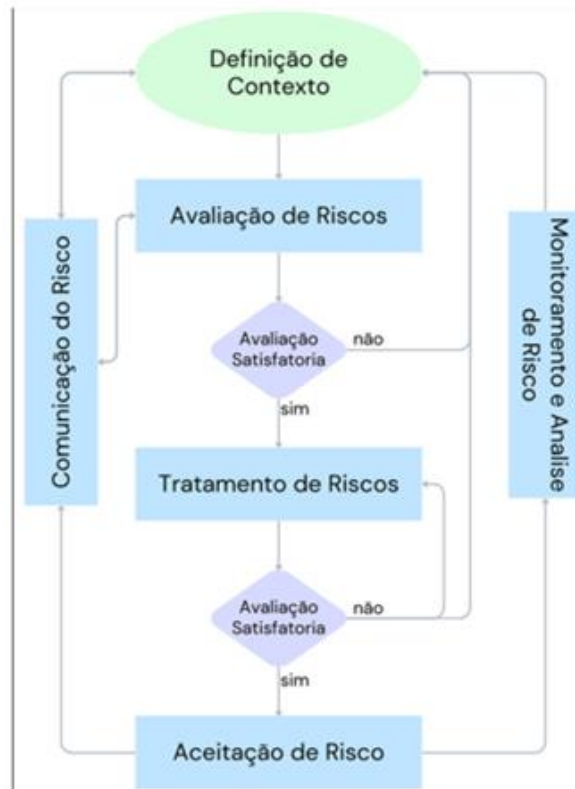


Conceitos básicos de segurança da informação

Processo de Gestão de Risco 27005:2011

O processo genérico implementado pela norma ABNT NBR ISO/IEC 27005:2011 utiliza seis fases: definição de contexto; processo de avaliação de riscos; tratamento do risco; aceitação do risco; comunicação e consulta do risco; monitoramento e análise crítica de riscos.

Processo de Gestão de Risco 27005:2011



Identificação de riscos:

- Identificação de ativos
 - Inventário, escopo e limites são essenciais para gera uma lista de ativos que devem ser gerenciados frente aos seus riscos.
- Identificação de ameaças
 - Por meio de registros de incidentes e eventos de segurança é possível formular uma lista de ameaças possíveis.

- Repare que “eventos de segurança” não diz respeito somente a ataques cibernéticos, mas pode também estar dizendo respeito a outros eventos que ameaça a segurança dos ativos, como eventos climáticos (como inundações) ou de segurança da infraestrutura (como combate ao fogo) que também podem ser avaliados na gestão de risco, caso seja necessário.

Identificação de riscos:

- Identificação de controles
 - É necessário saber que tipos de controles e monitoramentos são utilizados e quais se planeja utilizar e implementar.
- Identificação de vulnerabilidades
 - Ameaças conhecidas, lista de ativo e lista de controles já existentes.

- Identificação de consequências
 - Analisando tudo produzido anteriormente é possível criar uma lista com cenários e incidentes e então projetar quais seriam suas consequências aos ativos e aos processos do negócio.

Análise de riscos:

- Estimativa de consequências
 - Utilizando a lista feita pela identificação de consequências é possível avaliar o impacto que esses possíveis eventos trariam a organização.

- Estimativa da probabilidade de incidente
 - Considerando a lista de controle e de consequências é possível estimar a chance de incidentes ocorrerem, gerando uma lista de probabilidade e prioridades.
- Estimativa do nível de risco
 - Utilizando a lista de consequências em conjunto com a de probabilidade é feita uma valoração onde se atribui níveis aos riscos.

- Caso o resultado seja considerado satisfatório, passamos para a etapa de tratamento de risco. Com os riscos identificados e avaliados, a organização precisa desenvolver estratégias para tratar estes riscos. As estratégias podem incluir a mitigação dos riscos, a transferência dos riscos, aceitação dos riscos ou rejeição do risco.

- A mitigação de riscos envolve a implementação de medidas e controles novos que reduzem a probabilidade de ocorrência ou o impacto de um risco. Já a transferência de riscos é quando a organização transfere parte ou todo impacto dos riscos para outra entidade. Geralmente o impacto é calculado em termos financeiros e é transferido por meio de seguros.

- Por fim, a etapa de tratamento de riscos deve gerar um relatório que detalhe o plano de tratamento de risco e uma lista com os riscos residuais. Ao mesmo tempo que seguimos na caminhada do processo como um todo, este plano e lista devem ser entregues ao processo de monitoramento.

- No caso de o relatório ser considerado satisfatório chegamos a etapa de aceitação do risco. Com o plano do tratamento de riscos e a avaliação de riscos residuais em mãos, é necessário a aceitação formal dos riscos remanescentes e o OK para o plano de tratamento ser implementado. É necessário que a aceitação seja documentada explicitando todos os riscos que estão sendo aceitos pela organização.

- Por fim, o processo “termina” em duas etapas simultâneas e que estão sempre sendo efetuadas ao longo do processo, a de comunicação do risco e a de monitoramento e análise de risco. A comunicação de risco é a fase em que a organização comunica as informações relacionadas aos riscos de segurança da informação a todas as partes interessadas relevantes. Isso inclui relatar os resultados da avaliação de riscos, as estratégias de tratamento e as decisões de aceitação. A comunicação eficaz é crucial para garantir que todas as partes interessadas tenham conhecimento dos riscos e das medidas de mitigação a serem implementadas.